

Everything open on V1.36

Every issue from this sweep in one place — the live role audit, the CI/CD pipeline health, the UI defects, and the API contract findings. Each entry carries its status, including the ones deliberately **not** filed and why.

Env `acme.qa.egalvanic.ai` Roles swept 6 of 7 live

Workflows audited 13 · all 3 suites · 99 failures individually classified Writes made none As of 26 Aug 2026

5
High

10
Medium

11
Low / deferred

11
Investigated, dropped

Access control 3 issues · 1 High

RBAC-1 HIGH filed regression: 18 Jun → 9 Jul

The Technician role has web access and outranks the Project Manager

The suite's `technicianCannotAccessWeb` asserts a Technician holds no `platform.web` and hits a “Web Access Restricted” page. Live, the account signs straight into `/dashboard` with **93** permissions — more than the Project Manager — including `quotes.approve`, `accounts.manage` and `data.export`.

ROLE	PERMISSIONS	PLATFORM.WEB
Admin (reports as “Super Admin”)	111	yes
Technician	93	yes — should be no
Project Manager	90	yes
Account Manager	79	yes
Facility Manager	75	yes
Client Portal	34	yes

Created	Quote	Opportunity	Facility	Type	Value	Status	Actions
Aug 19, 2026	Android Site 2 - QUOTYE	Android Site 2 - QUOTYE	Android Site 2	EMP	\$0.00	Draft	
Aug 18, 2026	Quote	QA-ACME opp control — delet	Android Site 2	Standard	\$0.00	Draft	
Aug 14, 2026	test	abhiyant 14	Android Qa Site1	EMP	\$0.00	Draft	
Aug 12, 2026	Android Site 2 - EMP	Android Site 2 - EMP	Android Site 2	EMP	\$5.78	Draft	
Aug 9, 2026	QA-AUTO PR1127 persistent-window 2026-08-10T 29 july abhiyant v1-1		Android Site 2	Standard	\$0.00	Draft	
Aug 6, 2026	Android Site 2 - EMPdfdfdfdfdfdfdfdfdfdf	Android Site 2 - EMPdfdfdfdfdf	Android Site 2	EMP	\$0.00	Draft	
Aug 6, 2026	Quote 07 Aug	31 july - Opportunity 2	(s) Wild Goose Brewt	Standard	\$3,750.00	Draft	
Aug 6, 2026	test kd 2	31 july - Opportunity 2	(s) Wild Goose Brewt	EMP	\$27,732.26	Draft	
Aug 6, 2026	test kd 1	31 july - Opportunity 2	(s) Wild Goose Brewt	Standard	\$0.00	Draft	
Jul 30, 2026	Quote 31 july	31 july - Opportunity 2	(s) Wild Goose Brewt	Standard	\$3,500.00	Draft	

Signed in as the Technician: 131 quotes, per-row values, customer names, a **New Quote** button and a delete control on every row.

Because the Technician holds `forms.manage` and `reports.manage` and the Project Manager does not, the Technician can open the Forms and Report Builders while the PM gets **Access Denied**. CI dates the change: the assertion passed 18 Jun and has failed every run since 9 Jul — about seven weeks.

Corroborated by CI's own contract test (Suite 2, RBAC — API):

```
PRIVILEGE ESCALATION: matrix does NOT grant 'platform.web'
to 'Technician' but /auth/me returns it.
```

Open product question that sets severity: is the Technician meant on the web at all? If yes, the permission set still needs pruning. If no, the `platform.web` grant is the whole bug. **Verified on QA only** — role definitions drift `QA↔prod`.

RBAC-2 **MEDIUM** new live sweep + CI agree

The Customers nav entry is gated and placed inconsistently across roles

Two roles holding the identical feature flag get different navigation. The CI gating test flags it independently:

```
UI gating mismatch for 'Project Manager':
• Customers (features.accounts.view): should be HIDDEN (role lacks perm)
```

but is VISIBLE – gating bug

ROLE	FEATURES.CUSTOMERS.VIEW	FEATURES.ACCOUNTS.VIEW	CUSTOMERS APPEARS
Admin	yes	no	under Sales
Account Manager	yes	yes	under Sales
Technician	no	yes	under Sales
Project Manager	yes	no	under Operations
Facility Manager	yes	no	nowhere
Client Portal	no	no	nowhere

PM and FM hold the same `features.customers.view`, yet PM sees Customers and FM does not — and PM sees it under a different category than everyone else. Either the flag that gates this item is ambiguous (two candidates in play) or the placement rule is role-specific by accident.

RBAC-3 MEDIUM from Suite 2 · RBAC — API (606 TCs)

The live permission sets have drifted from the recorded permission matrix — beyond the Technician

The contract test compares each role's live `/auth/me` against the recorded 555-grant matrix. 33 cells fail, and not only for the Technician:

```
PRIVILEGE ESCALATION: matrix does NOT grant ... but /auth/me returns it:
Technician      platform.web
Account Manager  ir_photos.upload · features.issues.view · features.arc_flash.view
Facility Manager features.panel_schedules.view · features.opsdb.view
... 33 failing cells total
```

Either roles were re-provisioned without the matrix being updated, or the grants moved without review. Both readings mean the recorded matrix can no longer be trusted as the source of truth — re-baseline it once RBAC-1 is decided.

Security 1 issue · High · live-verified

SEC-1 HIGH ZP-2025 already open re-verified live 26 Aug

The login endpoint has no rate limiting, lockout or CAPTCHA

Two independent CI tests flagged it in different shards, and it reproduces on demand. Twelve consecutive failed logins against `/api/auth/login`:

```
status      401 401 401 401 401 401 401 401 401 401 401 401
throttled   0          (no 429 / 423 / 403)
Retry-After header  absent on every response
latency     1021 569 900 944 941 361 909 744 821 349 352 354 ms
                                                    ↑ gets FASTER – no backoff at all
body        { "error": "Invalid credentials" }
```

Corroborating CI evidence, from two separate suites:

```
Suite 1  AuthenticationTestNG.testTC_SEC_02_LoginRateLimitAfterFailures
         10 failed logins → 401 ×10, zero throttle responses
Suite 2  SecurityAuditTestNG.testBUG008_NoRateLimiting
         6 failed logins → 0 rate-limit / lockout / CAPTCHA signals
```

Unlimited unthrottled password guessing against a real auth endpoint. Already ticketed as **ZP-2025**, so this is a regression-tracking confirmation rather than a new find — but it is the highest-severity thing standing open in this sweep, and the suite has been reporting it every run.

CI / CD pipeline 8 issues · 2 High

CI-1 **HIGH** filed

The rerun-failed job cannot finish, and it masks every suite behind it

On the 25 Aug full suite it ran **4h00m51s** and was killed. That single job is what turns a run whose summary job was green into a cancelled badge — so the pipeline reports failure for a suite that largely passed, and nobody can read the result at a glance.

```
Parallel Full Suite – Core Regression (32860997278)
  21 jobs · 20 success · 1 cancelled ← rerun-failed, killed at 4h00m51s
  total wall clock 6h40m57s          vs 3h23m31s on 2026-08-22 – roughly double
```

```
Parallel Suite 2 – Curated + AI + Smoke + Load (32861054054)
  36 jobs · 35 success · 1 cancelled ← rerun-failed, killed at 2h01m40s
  cancels on the same pattern every run:
  2026-08-25 4h09m 2026-08-22 4h26m 2026-08-21 4h19m
```

Root cause is downstream of **FW-1** and **CI-4**: ~310 spurious failures between them are what give the rerun step hours of work to chew through.

FW-1

MEDIUM

framework, not product

252 failures

The Create Work Order dialog was redesigned into a 4-step wizard — the framework doesn't know

Suite 2's Work Type shards failed wholesale: Create Dialog Matrix **151/153**, Create E2E **42/42**, Auto-Schedule **33/33**, Detail Contract 26/102 — every failure the same timed-out wait in `WorkOrderPage`, which still targets the v1.35 single-form dialog.

Live check: the dialog is now a wizard — **Work order → Scope → Team → Review** — with a “Service to Perform” selector and live scope resolution. And it **works**:

```
step 1  name + facility + service picked
        WILL RESOLVE TO: 2 assets — every ATS at Android Site 2
step 2  “2 matching assets · 7 of 7 issues” — per-asset issue
        untick list renders (cancelled before create; no data written)
```

So this is **framework debt, not a product outage** — the same class of break as the v1.35 redesign (ZP-3000). Until `WorkOrderPage` is realigned, ~40% of Suite 2 is noise, and it is the biggest single feeder of CI-1's rerun pile-up.

CI-2

HIGH

red 10/10 runs

API Health Check has failed every scheduled run for 10 consecutive days

`parallel-suite-3.yml` is **0 for 10** — failing daily since ~17 Aug and still failing today (run 32938341382, 26 Aug). The endpoint sweep itself is healthy; a single probe fails the job.

```
API Health Check — 50 endpoints · 49 pass · 1 warn · 0 fail · avg 255ms

failing probe (error-contract audit):
  malformed-path  FAIL    12 ops x 4 junk values → 5xx = 12
```

That probe is the same malformed-path-param class already reviewed and **deferred** (see UI-5). So the red is real but its content is known and low-priority — which is worse, not better: a permanently-red daily job trains everyone to ignore it, and a genuine API regression would land invisibly.

CI-3

MEDIUM

Both RBAC workflows are majority-red

WORKFLOW	LAST 10 RUNS	CAUSE
rbac-ui-tests.yml	3 pass / 7 fail	RBAC-2 (Customers gating)
rbac-login-tests.yml	5 pass / 5 fail	RBAC-1 + Facility Manager landing route

These two reds are **signal, not noise** — they are the tests that caught RBAC-1 and RBAC-2. They

CI-4 **MEDIUM** not a product bug

58 spurious Asset Engineering failures inflate every run

All 58 share one signature — empty option lists (got: , found 0, found []). A live check explains them without a product defect:

```
GET /api/node_classes    636 classes, 13 tenant copies of each
```

```
Motor Starter    definition[] = 0  in ALL 13 copies, incl. the global one
VFD              definition[] = 0  in ALL 13 copies
Circuit Breaker  9 defs (15 for ACME)
Transformer      17 defs (26 for ACME)
Panelboard       10 defs (16 for ACME)
```

```
295 of 636 classes (46%) carry zero definitions —
Cable, Load, DC Bus, Battery, Capacitor Bank, Rectifier ...
```

Motor Starter and VFD have no engineering attributes *in every tenant including the global copy*, and 46% of classes are attribute-free in a way that looks deliberate — a Cable does not need a phase configuration. This reads as **test expectations asserting a schema that was never defined**. No pass→fail window could be established, so it is **not filed as a product defect** — but it is the fuel for CI-1.

CI-5 **MEDIUM**

A green job does not mean the tests passed

Shard jobs report success while carrying failures inside, because the workflow tolerates them and defers to the rerun step. Across the two dispatched suites on 25 Aug that produced **55 green jobs over ~506 actual test failures** — 83 in Suite 1, ~423 in Suite 2. Anyone reading job status is reading the wrong number.

Suite 1 — Core Regression (848 TCs):

SHARD	RUN	FAILED	BUGS	TEST/DATA	ENV
Asset Eng / exhaustive options	308	35	35	0	0

SHARD	RUN	FAILED	BUGS	TEST/DATA	ENV
Asset Eng / per-class matrix	39	10	10	0	0
Asset Eng / Trip Config	12	7	7	0	0
Asset Eng / Mains Config	17	5	2	3	0
Asset Eng / Transformer	10	4	4	0	0
Work Order + Issue	249	17	0	16	1
Auth + Site	59	3	—	—	—
Asset Part 5 · Opportunities	122	2	0	2	0

Suite 2 — Curated + AI + Smoke + Load (the largest failure blocks; see FW-1 for the Work Type rows):

SHARD	RUN	FAILED	EXPLANATION
Work Type — Create Dialog Matrix	153	151	FW-1 — stale page objects
Work Type — Create E2E Matrix	42	42	FW-1
Work Type — Auto-Schedule & Edge	33	33	FW-1
Work Type — Detail Contract	102	26	FW-1 (triaged Test/Data)
Quality Gates (All Pages)	178	52	mislabelled — see A11Y-1
Asset Engineering (5 shards)	386	60	CI-4 — empty-schema expectations
RBAC — API	606	33	RBAC-1 + RBAC-3 — real signal
Documentation-Inspired	17	7	SPA catch-all family (UI-3 / UI-5, deferred)
Arc Flash (8 shards)	≈130	6	3 triaged Bugs — unreviewed

CI-6 LOW

Four workflows have gone dormant

smoke-tests.yml	last run 2026-04-24	(4 months)
full-suite.yml	last run 2026-04-27	(4 months)
rbac.yml	last run 2026-06-18	(2 months)
web-tests-smoke-repodeveloper	last run 2026-04-27	(4 months)

All were green when last run, so nothing is failing — but a smoke suite that has not executed since April is not providing coverage. Either retire them or wire them to a schedule.

CI-7 **LOW** hygiene

Runner warnings accumulating

Selenium cannot match a CDP implementation for Chrome 151 (Unable to find version of CDP to use for 151.0.7922.137), logged on every browser start; and GitHub reports actions/checkout, setup-java, upload-artifact and setup-chrome still targeting the deprecated Node 20. Neither breaks a run today.

UI / functional 5 issues · all reviewed and deferred by the owner

UI-1 **LOW** owner: not a blocker documented

Sorting a paginated grid only sorts the rows already loaded

/assets (172 rows) and /connections (183) paginate server-side but sort in the browser over the current page. Rows outside it are never compared, and the header still shows a normal descending arrow.

25/page → top row 8N-H1-2

100/page → top row CB1

Same sort, same arrow, different answer — the sort never reaches the server (? page=1&page_size=25 carries no sort parameter).

UI-2 **LOW** owner: not a blocker

The Created column cannot be sorted

On /sessions and /emps it loads descending and stays. Three clicks change nothing — no reorder, no axis-sort change, no request — while control columns on the same grids (Due Date, Site) work

UI-3 LOW owner: very low priority

A raw JavaScript error is shown as the user-facing message

Five detail routes print the parser exception verbatim when the record does not exist:

```
Unexpected token '<', "<!DOCTYPE "... is not valid JSON

/assets/{dead-uuid} · /sessions/{dead-uuid} · /issues/{dead-uuid}
/plans/{dead-uuid} · /plans/12345
```

The friendly handler already exists — /assets/not-a-uuid returns “This asset link doesn't look right.” It is simply not wired to the missing-record branch.

UI-4 LOW owner: very low priority

/customers/{missing} renders a completely blank page

No message, no error, no way back — nav chrome and an empty content area. Worse than UI-3, which at least says something went wrong and offers a link.

UI-5 LOW owner: very low priority fails CI-2 daily

Malformed path params return 500 instead of 400

```
500 eg-form-instance/by-session/not-a-uuid-at-all/count
500 eg-form-instance/by-session/not-a-uuid-at-all/node-status
body: {"error":"internal_error","success":false,"trace_id":"333e2060..."}
```

Body is properly sanitised — no SQL, no stack. Only the status code is wrong. Deferred as a product issue, but note it is the sole cause of **CI-2**'s permanent red.

A11Y-1 MEDIUM axe-core, not DOM greps ~48 routes

Quality Gates' 52 failures were mislabelled — they are axe-core WCAG violations

Correction to an earlier statement in this register. I reported these as “all triaged Test/Data.” That label was the triager's *fallback* — 40% confidence, root cause “Unclassified failure — needs manual investigation.” Reading the actual assertions shows something different: roughly 48 are

A11yVerifier findings produced by **axe-core**, the rule engine rather than the attribute-counting that invalidated my earlier accessibility pass.

```
most frequent rules, by route

[critical] button-name      /users 70 nodes · /sessions 25 · /site-walks 24
                             · /attachments 8 – per-row action IconButton
[serious] color-contrast   /issues 19 nodes · /tasks 26 · /services 23
[serious] aria-progressbar-name  MuiCircularProgress / LinearProgress
[critical] aria-required-children  MuiDataGrid – /emps /goals /test-equipment
[serious] aria-input-field-name  MuiSelect – /reporting/builder 11 nodes
```

Worth reading before acting: on /users the note records that the row buttons' aria-label sits on an inner span rather than the button – a genuine axe violation whose real-world impact is small. And the aria-required-children hits are on MuiDataGrid, the same component whose grid semantics were reviewed and accepted earlier. **Treat this as a prioritised backlog, not a bug list** – but it is a real axe-core result, and the register should not have said otherwise.

API contract from the Suite 3 audit · 49/50 endpoints healthy

API-1 **MEDIUM**

Six of seven list APIs are unbounded

ENDPOINT	ROWS RETURNED	PAGINATED	FILTER
/node_classes	636	no	ignored
company/.../opportunities	263	no	ignored
lookup/nodes/{sld}	233	no	ignored
company/.../slds	230	no	ignored
/edge_classes	54	no	ignored
/issue_classes	37	no	ignored
sld/.../library-designations	25	yes	yes

API-2 **MEDIUM** flagged critical by the audit

Payload and latency outliers

/node_classes	5306 KB	636 items	663ms	← critical
/lookup/procedures	2031 KB	1196 items	398ms	
company/.../sessions	1372 KB	1123 items	1924ms	← slow + large + unpaginate
/lookup/node-classes	638 KB	46 items	149ms	
/z-university/pages	85 KB	23 items	3582ms	← slowest endpoint
company/.../workorders?per_page=5		worst observed	5398ms	

API-3 **MEDIUM**

Array-form filter returns HTTP 500

On POST /api/v2/issues/list — the one paginated, filterable list API — the scalar form works and the array form faults:

```
status='open'      → 200, 32 issues
status=['open']    → HTTP 500
```

API-4 **LOW**

Robustness gaps reported by the audit (not enforced)

unknown-resource

40 ops probed with nonexistent ids: **0** return 404, **34** return 200.

required-field-enforcement

4 creates missing required fields were **accepted**, 0 rejected.

async-convergence

Queued mutations take up to **24s** to become readable.

Response shape drift

6 endpoints return a bare array instead of {success, data}.

All are report-only in the suite (STRICT_* gates off) and none leak internals — the leakage probe found 0 across 6 attempts, and unauthenticated GETs were correctly refused on 38 of 40 ops.

Investigated and dropped 6 candidates that did not survive verification

WHY THIS SECTION EXISTS

Each of these looked like a defect and was killed by a specific check. Recording them stops the same false positive being re-filed next sweep.

PM denied Forms / Reports / Services

Route gates key on `.manage`, not `.view`; PM genuinely lacks `forms.manage`. **Correct behaviour.**

PM nav missing Planned Work

Nav keys on `features.planning.view`, which PM lacks — and Technician and FM, who hold it, *do* see the link. **Consistent.**

Client Portal data exposure

13 routes probed as the external role: 10 Access Denied, 3 render with zero rows. **No leak.**

/admin/audit-log hangs

Renders Access Denied correctly — the first read caught it mid-render. **Dropped.**

alliance-config 500 blocking login

Did not recur: **12/12** consecutive 200s. **Dropped.**

Assets Condition column will not sort

The column is empty across the dataset — nothing to sort. **Not a defect.**

Arc Flash — 3 “Bugs”, now resolved

All 6 Arc Flash failures trace to fixture-site selection failing (`'Android Qa Site1'` selected=`false`; Eng-E2E's site missing entirely → 10 skips). AFC_03 is **refuted by a same-run positive control** — AFC_04 passed using the very field AFC_03 called missing.

Quotes search is case-sensitive

CI: `'account'` → 10 rows, `'ACCOUNT'` → 1. Live: all four casings return identical results. **Does not reproduce.**

/users renders blank at 390px

Re-tested under true CDP mobile emulation (`innerWidth 390`): 331 visible nodes, 1097 chars. **Does not reproduce.**

Asset detail omits the asset name

Claimed by two tests. Live: `/assets/532b10d9...` renders “11N-H1-1” with all tabs. **Does not reproduce.**

OPEN-1 — Circuit Breaker subtype “found 0”

Closed. The dropdown returns **11** options live (Low-Voltage Molded Case, Medium-Voltage Vacuum, Recloser ...). Data present in `node_subtypes`. Test-side.

OPEN-2

NEEDS A PRODUCT ANSWER

not refuted, not confirmed

What is still genuinely open

Arc Flash “Select role” control absent

Missing across two independent shards even to self-healing locators, on a page that otherwise

Service catalog drift

`dga-fluid-sample-analysis` and `de-energized-testing` (NETA Testing) are pinned

rendered. But V1.36 *deliberately* removed the global role switcher — so this is plausibly intentional. One dev intent-check settles it.

by contract tests but missing from the live catalog. Renamed, or dropped?

WO list “Show planned” toggle

ZP-3027 regression test says the toggle is gone. Unverified — likely moved in the same redesign as FW-1.

Fixture sites may be gone

Android Qa Site1 and abhiyant 17 june site failed selection. If the *picker* is broken rather than the sites deleted, that would itself be a product bug — worth five minutes.

If only three things get done: answer the product question behind **RBAC-1** and check the production Technician role; realign `WorkOrderPage` to the new wizard (**FW-1**) so 40% of Suite 2 stops being noise and CI-1's rerun step can finish; and either fix or mute **CI-2** so a ten-day red stops training the team to ignore it.

Detail and reproduction steps live in the repo — `docs/bug-reports/2026-08-25-rbac-technician-web-access-and-overprivilege.md` and `docs/bug-reports/2026-08-25-grid-sort-page-local-and-created-column.md`. Nothing in this sweep created, modified or deleted any data.